

Shellcode 实验补充说明

1 概述

你需要按照 SEED Labs 实验手册（Homework_5_Manual_Shellcode.pdf，有中英文版）填写作业模板（Homework_5_template.docx）完成作业 5。本文档将某些操作进行具体说明，方便你顺利完成作业。

2 任务 1：编写汇编代码

本任务没有需要说明的内容。

3 任务 2：编写 Shellcode（方法 1）

3.1 任务 2.a. 理解代码

实验手册没有详细说明如何使用 gdb 指令调试，实际操作是在完成编译（nasm 指令）和链接（ld 指令）后，运行 `gdb mysh64` 开始调试。开始调试后，依次运行 `break one`、`run` 和 `step` 指令，可追踪程序运行。每次执行 `step` 指令都会刷新显示寄存器内容，如图所示：

```

gdb-peda$ run
Starting program: /home/seed/LabsetupShellcode/mysh64o
[-----registers-----]
RAX: 0x0
RBX: 0x0
RCX: 0x0
RDX: 0x0
RSI: 0x0
RDI: 0x0
RBP: 0x0
RSP: 0x7fffffff098 --> 0x4000a8 --> 0x68732f6e69622f ('/bin/sh')
RIP: 0x400082 --> 0xb8085b89485b
R8 : 0x0
R9 : 0x0
R10: 0x0
R11: 0x0
R12: 0x0
R13: 0x0
R14: 0x0
R15: 0x0
EFLAGS: 0x202 (carry parity adjust zero sign trap INTERRUPT direction overflow)
[-----code-----]
0x40007c: add BYTE PTR [rax],al
0x40007e: add BYTE PTR [rax],al
0x400080 <_start>: jmp 0x4000a3 <two>
  
```

在直接对机器代码进行 debug 时，有时执行 `step` 指令会出错或者运行结果不合预期。这种情况下可以改用 `stepi`（每次严格只执行一条指令）。

另外，在执行 `mysh64` 程序后，应会出现不含前缀的命令提示符，如下图所示。可以执行 `exit` 退出。

```

[04/05/26]seed@VM:~/LabsetupShellcode$ ./mysh64
$ █
  
```

最后，如果你运行程序时显示 `Segmentation Fault`，需注意链接时要加上 `--omagic`，使代码段可写。实验手册对此也有说明，你需要执行 `ld --omagic -o mysh64 mysh64.o` 而不是 `ld mysh64.o -o mysh64`。

3.2 任务 2.b. 消除代码中的零

除了按实验手册 5 指南：去除零的方法 操作外，对于操作数本身含 0 的指令也可以用减法代替，例如 `mov rax, 59` 可以用 `mov rax, 0x1111114c` 和 `sub rax, 0x11111111` 代替。

3.3-3.4 任务 2.c, 2.d. 运行更复杂的命令/传递环境变量

这两个任务没有需要说明的内容。

4 任务 3: 编写 Shellcode (方法 2)

使用栈方法可能需要事先进行栈的模拟，你可以使用 HxD 完成这项工作，如图所示，需要注意栈是先进后出（FILO）的，先入栈的数据在最底部（内存地址最大）：

```
00000056  2F 62 69 6E 2F 62 61 73  /bin/bas
00000064  68 00 00 00 00 00 00 00  h.....
00000072  00 00 00 00 00 00 00 00  .....
00000080  2D 63 00 00 00 00 00 00  -c.....
00000088  00 00 00 00 00 00 00 00  .....
00000096  65 63 68 6F 20 68 65 6C  echo hel
00000104  6C 6F 3B 20 6C 73 20 2D  lo; ls -
00000112  6C 61 00 00 00 00 00 00  la.....
```

另外，如果需要直接以十六进制数的形式赋值，需注意小端序。例如：

```
mov rax, 'echo hel'
```

的十六进制对应是

```
mov rax, 0x6c6568206f686365
```

而不是

```
mov rax, 0x6563686f2068656c
```

6 提交

请在作业 5 模板（Homework_5_Template.docx）上完成，**生成 pdf 文件并提交**。不要提交.docx 文件。

附录：execve 指令的寄存器对应关系

Register	Purpose	Content for Task 2.c/d
rdi	Filename	Address of <code>"/bin/bash"</code> or <code>"/usr/bin/env"</code>
rsi	argv[]	Address of the array of pointers
rdx	envp[]	Address of the environment pointers (or 0 if none)
rax	Syscall ID	Must be 59